Исследование аномалий на pcap-файлах

В предыдущем отчете я исследовал теоретические основы аномалий трафика. В рамках этого отчета я буду исследовать трафик двух pcap-файлов: один файл содержит аномалии, второй - “чистый” трафик. Человек, пишущий парсер, предоставил 4 csv-файла: 1_flows.csv (потоки на грязном трафике), 1_windows.csv (временные окна на грязном трафике), и 26_flows.csv, 26_windows.csv на чистом трафике соответственно.

1. **Анализ аномального трафика (файл windows)**
   Файл содержит 259 записей 10-секундных интервалов с 03:23:20 по 04:06:30.

StartTime	EndTime	TotalPacke	TotalBytes	PPS	BPS	UniqueSrc	UniqueDst	UniqueSrc	UniqueDst	ActiveFlow	CntSYN	CntACK	CntFIN	CntRST	CntPSH	CntURG
2015-02-1	03:23:30.0	162	63284	16,20	6328,40	5	5	12	12	8	16	152	28	0	10	0
2015-02-1	03:23:40.0	416	88711	41,60	8871,10	12	11	30	30	23	80	372	72	0	24	0
2015-02-1	03:23:50.0	146	30928	14,60	3092,80	12	12	16	14	14	28	122	28	0	12	0
2015-02-1	03:24:00.0	224	94936	22,40	9493,60	11	11	15	14	13	32	200	36	0	16	0
2015-02-1	03:24:10.0	252	55106	25,20	5510,60	13	11	15	14	12	32	230	28	0	18	0
2015-02-1	03:24:20.0	118	17120	11,80	1712,00	13	13	10	9	11	20	92	24	0	4	0
2015-02-1	03:24:30.0	204	82883	20,40	8288,30	11	11	37	11	36	16	122	16	0	16	0
2015-02-1	03:24:40.0	362	161132	36,20	16113,20	13	13	75	17	73	36	218	20	0	10	0
2015-02-1	03:24:50.0	206	106341	20,60	10634,10	12	13	15	14	13	16	190	24	0	20	0
2015-02-1	03:25:00.0	266	155349	26,60	15534,90	13	13	17	16	15	28	240	32	0	2	0
2015-02-1	03:25:10.0	216	39234	21,60	3923,40	11	12	14	13	12	24	196	28	0	24	0

В начале наблюдения (до 03:37:40) трафик низкой интенсивности:

- PPS<50, BPS<25000
- Кол-во уникальных IP-адресов колеблется от 5 до 13
- Кол-во активных потоков до 15
- Флаги TCP (SYN, ACK, RST) присутствуют в небольших кол-вах

Резкое изменение поведения происходит в интервале **03:37:40 - 03:38:20**:

2015-02-1	03:37:40.0	2	160	0,20	16,00	2	1	1	1	2	0	0	0	0	0	0
2015-02-1	03:37:50.0	1114	125260	111,40	12526,00	34	33	220	220	181	440	576	40	0	10	0
2015-02-1	03:38:00.0	1254	242652	125,40	24265,20	31	30	233	232	181	436	672	36	0	14	0
2015-02-1	03:38:10.0	14264	2761792	1426,40	########	31	30	841	832	738	2032	12912	556	0	5452	0
2015-02-1	03:38:20.0	44178	17683768	4417,80	########	34	34	1194	1191	1010	1488	43110	3232	0	17608	0

PPS скаканул с ~100 до >4000, BPS – с десятков тысяч до миллионов, количество уникальных IP-адресов и портов возрастает в 2–3 раза, что указывает на вовлечение многих хостов (возможно, ботнета) или сканирование.
Аномалии в TCP-флагах – большое количество пакетов с SYN и RST при высоком числе ACK. Особенно выделяется окно 03:38:10–03:38:20, где на 1488 SYN приходится 17 608 RST и 43 110 ACK.
Длительность аномалии – после пика интенсивность остаётся высокой до конца записи, хотя и с колебаниями. Это говорит о продолжительном аномальном событии.
Что это может быть? На основе теоретических признаков из предыдущего отчета можно выдвинуть следующие гипотезы:

- DDoS-атака - резкий скачок BPS и PPS, большое количество SYN и RST
- Сканирование сети/портов – высокое число RST при SYN-пакетах, большое количество уникальных портов и IP

- Перегрузка – наблюдаемый высокий BPS может вызывать перегрузку каналов
- Деятельность червей – маловероятно, но на червя может указывать рост числа уникальных портов назначения и источников

1. **<u>Анализ аномального трафика (файл flows)</u>**

   Для анализа вручную я взял первые 1000 записей (оригинальный файл содержит около 45 тысяч)

	A	B	C	D	E	F	G	H	I	J	K	L	M	N
1	FlowID	Packets	TotalBytes	AvgSize	StdDevSize	BPS	IAT_ms	Duration_s	SYN	ACK	FIN	PSH	RST	URG
2	149.171.12	40	6144	153,60	271,97	2844,33	55	2,1601	4	38	4	12	0	0
3	149.171.12	4	388	97,00	8,00	########	0	0,0011	0	0	0	0	0	0
4	149.171.12	8	968	121,00	35,93	########	0	0,0017	0	0	0	0	0	0
5	149.171.12	4	388	97,00	8,00	########	0	0,0010	0	0	0	0	0	0
6	149.171.12	18	1286	71,44	30,07	1990,68	38	0,6460	4	16	4	0	0	0
7	149.171.12	20	9568	478,40	628,42	43009,21	11	0,2225	4	18	4	4	0	0
8	149.171.12	26	1854	71,31	13,33	936,88	79	1,9789	4	24	4	0	0	0
9	149.171.12	56	10098	180,32	226,16	70763,34	2	0,1427	4	54	4	24	0	0
10	149.171.12	32	12364	386,38	531,87	10671,92	37	1,1586	4	30	4	10	0	0

   Я нашел следующие аномалии:

   Потоки с признаками сканирования

   Короткие потоки с малым числом пакетов (2–8 пакетов) и длительностью <0.01 сек – их много. Например:

   149.171.126.2:53-59.166.0.8:27428 (4 пакета, 0.0011 сек)

149.171.1	4	388	97,00	8,00	########	0	0,0011	0	0	0	0	0	0

   Такие потоки часто соответствуют DNS-запросам (порт 53), что нормально. Однако обратим внимание на количество потоков: 53, 63952, 55937, 50128, и т.д., их там свыше десятка – такое разнообразие портов назначения является признаком сканирования.

   Потоки с признаками DDoS

   Высокая интенсивность (BPS):

   149.171.126.4:80-59.166.0.3:1551 – BPS 967 255, 1104 пакета за 1.16 сек

149.171.12	1104	1124652	1018,71	682,51	########	1	1,1627	4	1102	4	372	0	0

   149.171.126.7:6881-59.166.0.6:47615 – BPS 67 214, 1320 пакетов за 16.9 сек

149.171.1	1320	1141796	865,00	702,83	67214,98	12	16,9872	4	1318	4	468	0	0

   Эти потоки могут быть частью DDoS-атаки, направленной на перегрузку канала или сервиса (порты 80, 6881). Однако BPS в десятки тысяч не является запредельным для современных сетей, но в совокупности с множеством таких потоков (их десятки) общая нагрузка становится критической, что и видно в окнах.

2. **<u>Анализ чистого трафика (файл windows)</u>**

   Файл содержит 164 записи с 14:53:50 до 15:21:10.

StartTime	EndTime	TotalPacke	TotalBytes	PPS	BPS	UniqueSrc	UniqueDst	UniqueSrc	UniqueDst	ActiveFlow	CntSYN	CntACK	CntFIN	CntRST	CntPSH	CntURG
2015-02-1	14:54:00.0	12460	7114962	1246,00	########	30	29	207	205	152	376	12074	360	0	4880	0
2015-02-1	14:54:10.0	27800	17483722	2780,00	########	34	33	345	343	245	628	27194	656	0	10604	0
2015-02-1	14:54:20.0	25934	15385445	2593,40	########	33	35	343	342	251	632	25268	698	0	9812	0
2015-02-1	14:54:30.0	24844	14183283	2484,40	########	34	33	359	357	241	676	24126	636	0	9510	0
2015-02-1	14:54:40.0	29926	19402000	2992,60	########	37	36	347	345	259	688	29220	636	0	11042	0
2015-02-1	14:54:50.0	29944	20245105	2994,40	########	34	33	354	351	250	608	29276	628	0	11156	0
2015-02-1	14:55:00.0	29242	18653029	2924,20	########	34	33	356	354	252	652	28574	708	0	10824	0
2015-02-1	14:55:10.0	17528	8078569	1752,80	########	34	33	344	340	235	640	16856	644	0	6920	0
2015-02-1	14:55:20.0	22426	12222338	2242,60	########	33	34	359	341	257	652	21706	648	0	8556	0
2015-02-1	14:55:30.0	17530	8272285	1753,00	########	34	34	347	326	242	600	16870	616	0	6870	0
2015-02-1	14:55:40.0	23476	13845800	2347,60	########	35	35	372	354	263	652	22716	628	0	8810	0
2015-02-1	14:55:50.0	25280	15061536	2528,00	########	32	32	356	338	248	620	24588	624	0	9660	0
2015-02-1	14:56:00.0	15420	6525664	1542,00	########	33	34	348	332	250	612	14734	628	0	5958	0

Статистика:
PPS (пакетов/с): от 1200 до 3000, пик - 3200
BPS (байт/с): 0.5 – 2.0 млн
UniqueSrcIPs / UniqueDstIPs: ~30–36 уникальных источников и назначений
ActiveFlows: 150–350.
CntSYN / CntACK / CntRST:
- **CntSYN**: 400–1100
- **CntACK**: 10 000–30 000
- **CntRST** = 0 почти что везде

В отличие от аномального pcap, здесь отсутствуют резкие скачки PPS/BPS. Нет окон с экстремальным ростом числа потоков или уникальных IP. Очень характерно отсутствие пакетов RST (CntRST = 0) – это значит, что не было грубых ошибок соединений, характерных для сканирования или DDoS.

2. Анализ чистого трафика (файл flows)

Я так же взял первые 1000 записей.
Статистика:
- Длительность: от 0 сек до 609
- Кол-во пакетов: от 2 до ~1500
- BPS: от единиц до 2.3 млн
- Поле RST везде =0

В трафике присутствуют потоки с малым числом пакетов (2-8) и малой длительностью (<0.01 сек), но в основном они исходят от порта 53 (DNS-запрос). Разнообразие портов не превышает десятка, что не характерно для сканирования. Хорошим знаком является отсутствие голых SYN-пакетов и RST = 0. Пакеты с BPS около 2 млн могут указывать на передачу больших объемов данных, и без RST и аномального соотношения SYN/ACK исключают DDoS. Интересен порт 6881 - это BitTorrent, у которого более 100 потоков, такая P2P-активность может быть уязвима для червя, но никак не доказывает его прямое наличие. Признаки переключения потока отсутствуют т.к. нет потоков с адресами назначения класса D.

Таким образом, перед нами трафик сети высокой интенсивности с явным использованием P2P, но никаких аномалий выявлено не было